

Relatório do trabalho de grupo

Proposta de controlo de acessos para mini-servidor Linux

1. Identificação do grupo

Grupo: Breakout 9

- **Elementos:**

- o Carlina Pinto
- o Cleber Monteiro
- o Bruno Veiga

Papeis assumidos:

- o **Coordenação:** Responsável por organizar o trabalho e garantir que todos os requisitos sejam cumpridos.
- o **Perfis e grupos:** responsável por propor os grupos admins, webops, auditores e visitantes.
- o **Estrutura de diretórios e permissões:** responsável por definir a organização de /opt/projeto-web/ e as permissões adequadas.
- o **SSH, riscos e mitigação:** responsável por definir regras de acesso remoto e identificar riscos de segurança.
- o **Redação e revisão final:** responsável por organizar o relatório final e preparar o PDF.

Papeis:

- Coordenação: Carlina Pinto
- Perfis e grupos: Carlina Pinto
- Diretórios e permissões: Cleber Monteiro
- SSH, riscos e mitigação: Bruno Veiga
- Redação e revisão final: Todos

2. Síntese do cenário

O grupo analisou o cenário de um mini-servidor Linux que será utilizado para alojar uma aplicação web. Antes da publicação do serviço, é necessário definir uma primeira camada de controle de acessos, garantindo que cada perfil de utilizador tenha apenas as permissões necessárias para cumprir a sua função.

O servidor será usado por diferentes perfis: administradores do sistema, operadores web, auditores e visitantes técnicos. Cada perfil possui necessidades diferentes, como administrar o sistema, publicar ficheiros da aplicação, consultar logs e documentação, ou aceder apenas a informação pública autorizada.

A proposta do grupo procura organizar os acessos através de grupos Linux, aplicar permissões adequadas aos diretórios do projeto, respeitar o princípio do menor privilégio e definir regras básicas para acesso remoto seguro por SSH.

3. Perfis, grupos e responsabilidades

Para organizar o controle de acessos no mini-servidor Linux, o grupo propõe a utilização de contas individuais associadas a grupos específicos. Esta abordagem evita o uso de contas partilhadas, melhora a rastreabilidade das ações e permite aplicar o princípio do menor privilégio.

Perfil	Grupo sugerido	Responsabilidades	Permissões necessárias	Permissões a evitar
Administrador do sistema	admins	Gerir utilizadores, permissões, serviços e atualizações.	Acesso administrativo com sudo e controle das áreas críticas.	Uso direto/frequente de root e contas partilhadas.
Operador web	webops	Publicar e atualizar ficheiros da aplicação web.	Leitura/escrita em public/ e acesso limitado à documentação.	Acesso a config/, alteração de logs e privilégios administrativos globais.
Auditor	auditores	Consultar logs, evidências e documentação técnica.	Leitura em logs/ e docs/.	Alterar logs, modificar aplicação ou aceder a configurações sensíveis.
Visitante técnico	visitantes	Consultar apenas documentação autorizada.	Leitura limitada em docs/.	SSH sem necessidade, escrita em pastas e acesso a config/ ou logs/.

A utilização destes grupos permite separar responsabilidades e controlar melhor o acesso aos recursos do servidor. Cada utilizador deve possuir uma conta individual e ser associado apenas ao grupo necessário para desempenhar a sua função.

4. Estrutura de diretórios proposta

Para organizar os ficheiros do mini-servidor Linux, o grupo propõe a criação da seguinte estrutura base:

/opt/projeto-web/

├── public/

├── config/

```

└─ logs/
└─ docs/

```

Cada diretório terá uma função específica, permitindo separar ficheiros públicos, configurações sensíveis, registos do sistema/aplicação e documentação autorizada.

Diretório	Tipo de ficheiros	Quem deve poder ler	Quem deve poder escrever	Quem não deve ter acesso
/opt/projeto-web/public/	Ficheiros públicos da aplicação web, como HTML, CSS, imagens e scripts públicos.	admins e webops; o serviço web também poderá ler estes ficheiros.	admins e webops.	auditores e visitantes não devem escrever nesta pasta.
/opt/projeto-web/config/	Ficheiros de configuração da aplicação, variáveis sensíveis e parâmetros internos.	Apenas admins e, se necessário, o serviço da aplicação.	Apenas admins.	webops, auditores e visitantes, pois podem existir dados sensíveis.
/opt/projeto-web/logs/	Logs de acesso, erros, eventos e evidências técnicas.	admins e auditores.	O sistema/serviço e admins.	webops e visitantes não devem alterar logs.
/opt/projeto-web/docs/	Documentação técnica, instruções autorizadas e informação pública controlada.	admins, auditores e visitantes, conforme o nível de autorização.	admins; eventualmente auditores apenas para documentação de evidências, se autorizado.	Visitantes não devem escrever ou alterar documentação.

Esta separação reduz riscos de exposição de informação sensível e facilita a aplicação do princípio do menor privilégio. A pasta config/ deve ser a mais restrita, pois pode conter dados críticos. A pasta public/ deve permitir atualização pelos operadores web, mas sem conceder privilégios administrativos. A pasta logs deve preservar a integridade das evidências, permitindo leitura aos auditores, mas evitando alterações indevidas. A pasta docs deve conter apenas documentação autorizada para consulta.

5. Proposta de permissões

Para aplicar o princípio do menor privilégio, o grupo propõe que cada diretor tenha um dono, um grupo associado e permissões compatíveis com a função de cada perfil. Assim, evita-se o uso de

permissões excessivas como 777, que permitiriam leitura, escrita e execução para todos os utilizadores.

Caminho	Dono/grupo sugerido	Permissão sugerida	Justificação
/opt/projeto-web/	root:admins	750	A estrutura principal do projeto deve ser controlada pelos administradores. O dono tem controle total, o grupo admins pode aceder, e outros utilizadores não têm acesso direto.
/opt/projeto-web/public/	root:webops	775	Os operadores web precisam publicar e atualizar ficheiros públicos da aplicação. O grupo webops pode ler, escrever e entrar no diretório.
/opt/projeto-web/config/	root:admins	750	A pasta de configuração pode conter informação sensível, como parâmetros internos ou credenciais. Apenas administradores devem ter acesso.
/opt/projeto-web/logs/	root:auditores	750	Os auditores precisam consultar logs e evidências, mas o acesso deve ser limitado para evitar exposição ou alteração indevida por outros perfis.
/opt/projeto-web/docs/	root:visitantes	750	A pasta de documentação pode ser consultada por visitantes técnicos autorizados, mas a escrita deve continuar controlada para evitar alterações não autorizadas.

Exemplos de comandos que poderiam ser utilizados para aplicar esta proposta:

- ☐ sudo mkdir -p /opt/projeto-web/{public,config,logs,docs}
- ☐ sudo chown root:admins /opt/projeto-web
- ☐ sudo chown root:webops /opt/projeto-web/public
- ☐ sudo chown root:admins /opt/projeto-web/config
- ☐ sudo chown root:auditores /opt/projeto-web/logs
- ☐ sudo chown root:visitantes /opt/projeto-web/docs
- ☐ sudo chmod 750 /opt/projeto-web
- ☐ sudo chmod 775 /opt/projeto-web/public
- ☐ sudo chmod 750 /opt/projeto-web/config

- ☐ sudo chmod 750 /opt/projeto-web/logs
- ☐ sudo chmod 750 /opt/projeto-web/docs

Estas permissões permitem separar responsabilidades. Os administradores controlam a estrutura geral e as configurações. Os operadores web atualizam apenas os ficheiros públicos da aplicação. Os auditores consultam logs e evidências sem alterar a aplicação. Os visitantes técnicos ficam limitados à documentação autorizada.

6. Regras de acesso remoto por SSH

O acesso remoto por SSH deve ser controlado com regras claras, pois representa uma porta de entrada para o servidor. O grupo propõe que cada utilizador tenha uma conta individual, evitando contas partilhadas. Desta forma, é possível identificar quem acedeu ao servidor, quando acedeu e que ações realizou.

Perfil	Pode aceder por SSH?	Tipo de autenticação	Justificação
Administrador do sistema	Sim	Preferencialmente chave SSH, com uso de sudo quando necessário	O administrador precisa gerir utilizadores, permissões, serviços, atualizações e configurações do servidor.
Operador web	Sim, se necessário	Chave SSH ou palavra-passe forte, com conta individual e sem privilégios administrativos globais	O operador web pode precisar publicar e atualizar ficheiros da aplicação na pasta public/, mas não deve ter controlo total do sistema.
Auditor	Sim, de forma limitada	Chave SSH ou palavra-passe forte, com acesso de leitura aos logs e documentação	O auditor pode precisar consultar evidências, logs e documentação, mas não deve alterar ficheiros da aplicação ou configurações.
Visitante técnico	Preferencialmente não	Apenas se houver necessidade justificada, com conta individual limitada	O visitante técnico deve consultar apenas documentação autorizada. O acesso SSH aumenta a superfície de risco e deve ser evitado quando não for necessário.

Regras propostas para SSH:

- Cada pessoa deve usar uma conta individual.
- Contas partilhadas devem ser evitadas.
- O login direto como root deve ser evitado.
- O uso de sudo deve ser reservado apenas aos administradores.
- Sempre que possível, deve-se preferir autenticação por chave SSH em vez de apenas palavra-passe.
- Palavras-passe devem ser fortes e não devem ser partilhadas.
- Chaves privadas nunca devem ser publicadas, enviadas em relatórios ou usadas como evidência.
- Evidências podem incluir comandos, estado do serviço SSH, IP local do servidor e exemplos de ligação, mas nunca passwords, chaves privadas ou ficheiros sensíveis.
- Os acessos devem ser documentados para facilitar auditoria e responsabilização.

7. Riscos e medidas de mitigação

O grupo identificou riscos associados à má gestão de identidades, permissões e acessos remotos. Para cada risco, foi proposta uma medida de mitigação baseada em boas práticas de administração Linux e no princípio do menor privilégio.

Risco	Impacto	Medida de mitigação
Todos os utilizadores usarem a mesma conta	Dificulta a identificação de quem realizou alterações, reduz a rastreabilidade e aumenta o risco de uso indevido.	Criar contas individuais para cada utilizador e associá-las aos grupos adequados.
Permissões excessivas em pastas do projeto como 777	Qualquer utilizador poderia ler, alterar ou executar ficheiros, aumentando o risco de alterações indevidas ou exposição de informação.	Aplicar permissões específicas com chmod, chown e grupos, seguindo o princípio do menor privilégio.
Acesso remoto por SSH sem regras claras	Pode permitir acessos desnecessários, dificultar auditoria e aumentar a superfície de ataque do servidor.	Definir quais perfis podem aceder por SSH, usar contas individuais e preferir autenticação por chave SSH quando possível.
Ficheiros de configuração acessíveis a utilizadores não autorizados	Pode expor credenciais, parâmetros internos ou informação sensível da aplicação.	Restringir a pasta config/ ao grupo admins e aplicar permissões como 750.

Audidores ou visitantes com permissões de escrita em logs ou documentação crítica	Pode comprometer a integridade das evidências e dificultar investigações futuras.	Permitir apenas leitura para auditores e visitantes autorizados; escrita deve ser limitada a administradores ou processos controlados.
Falta de documentação sobre quem pode fazer o quê	Pode causar confusão na administração, permissões incorretas e dificuldade em manter o servidor seguro.	Manter uma matriz de acessos documentada com perfis, grupos, permissões e responsabilidades.
Publicação de passwords, chaves privadas ou dados sensíveis evidência	Pode comprometer o acesso ao servidor e permitir uso indevido como por terceiros.	Nunca incluir passwords, chaves privadas, tokens ou ficheiros sensíveis no relatório, prints ou repositórios públicos.

Estas medidas reduzem a probabilidade de acessos indevidos, alterações não autorizadas e exposição de informação sensível. A organização por grupos e permissões específicas permite que cada perfil execute apenas as tarefas necessárias.

8. Conclusão

A proposta apresentada organiza a primeira camada de controle de acessos para um mini-servidor Linux destinado a alojar uma aplicação web. A solução baseia-se na criação de perfis e grupos específicos, como admins, webops, auditores e visitantes, evitando o uso de contas partilhadas e facilitando a responsabilização de cada utilizador.

A estrutura de diretórios proposta separar ficheiros públicos, configurações sensíveis, logs e documentação, permitindo aplicar permissões adequadas a cada área do projeto. Esta separação reduz o risco de exposição de informação sensível e evita que utilizadores tenham acesso a ficheiros que não são necessários para as suas funções.

As permissões sugeridas seguem o princípio do menor privilégio, garantindo que cada perfil tenha apenas o acesso necessário. Os administradores mantêm controle sobre o sistema, os operadores web podem atualizar ficheiros públicos, os auditores podem consultar logs e evidências, e os visitantes técnicos ficam limitados à documentação autorizada.

As regras de acesso remoto por SSH reforçam a necessidade de contas individuais, autenticação segura, restrição do uso de root e proteção de passwords e chaves privadas. Desta forma, a proposta contribui para um ambiente mais seguro, organizado e fácil de auditar.

Conclui-se que uma boa gestão de identidades e acessos é essencial antes da publicação de qualquer serviço web, pois reduz riscos, melhora a organização da equipa e fortalece a segurança do servidor Linux.

